

Movie Theatre Management System

Threat Modelling Report

DACS3203 Secure Software Development

Project 8

Yaser Al-Mulaiky – 60105056

Omar Suhail – 60104487

1. Project Overview

The Movie Theatre Management System MTMS is a JavaFX desktop application used on a theatre computer and connected to a local MySQL database called theater. It is an internal system for daily theatre work such as logging in, maintaining movie records, scheduling showtimes, booking tickets, recording payments, generating reports, and writing maintenance reports.

The application starts from the login screen, verifies the account against the users table, checks the password using BCrypt, and then routes the user to the correct interface depending on the role. The three internal roles are Manager, Staff, and Maintenance Staff.

1.1 Main User Roles

Role	Main Functions
Manager	Manage movies, manage showtimes, view sold tickets, generate reports, view maintenance reports
Staff	View showtimes, choose seat, book ticket, record payment
Maintenance Staff	Write maintenance reports and view maintenance reports

1.2 Main Modules

- Authentication and role routing
- Movie management
- Showtime management
- Ticket booking and payment
- Report generation
- Maintenance reporting
- Action logging

This module is directly implemented in the existing codebase. For example, UserLogin, AuthenticationService, and AuthorizationService helps with user authentication and login. The ManageMovie and AddMovie are used for performing actions related to movies. Similarly, ManageSchedule and AddShowtime can be utilized for performing actions regarding showtime. ShowAllShowtimes and BookTicket modules perform tasks associated with booking and payment process, respectively.

1.3 Main Data Stores and Assets

- user accounts, password hashes, failed-attempt counters, and roles
- movie records
- showtime records and room selection data
- ticket and payment records
- maintenance reports
- action log records
- local database contents and database access details

1.4 Trust Boundary

The trust boundary in this project is simple. The users are outside the trust boundary because their input cannot be trusted automatically. The MTMS application and the local database are inside the trust boundary. All important data reaches the database through the application layer, where validation, role-based routing, booking checks, and action logging take place.

2. Application Decomposition

To understand the threats properly, the system first needs to be broken into the parts that matter most. In this project, the important classes are the login and access-control classes, the entity classes that represent the stored data, the helper classes used for validation and database checks, and the screen classes that accept user input and execute database operations.

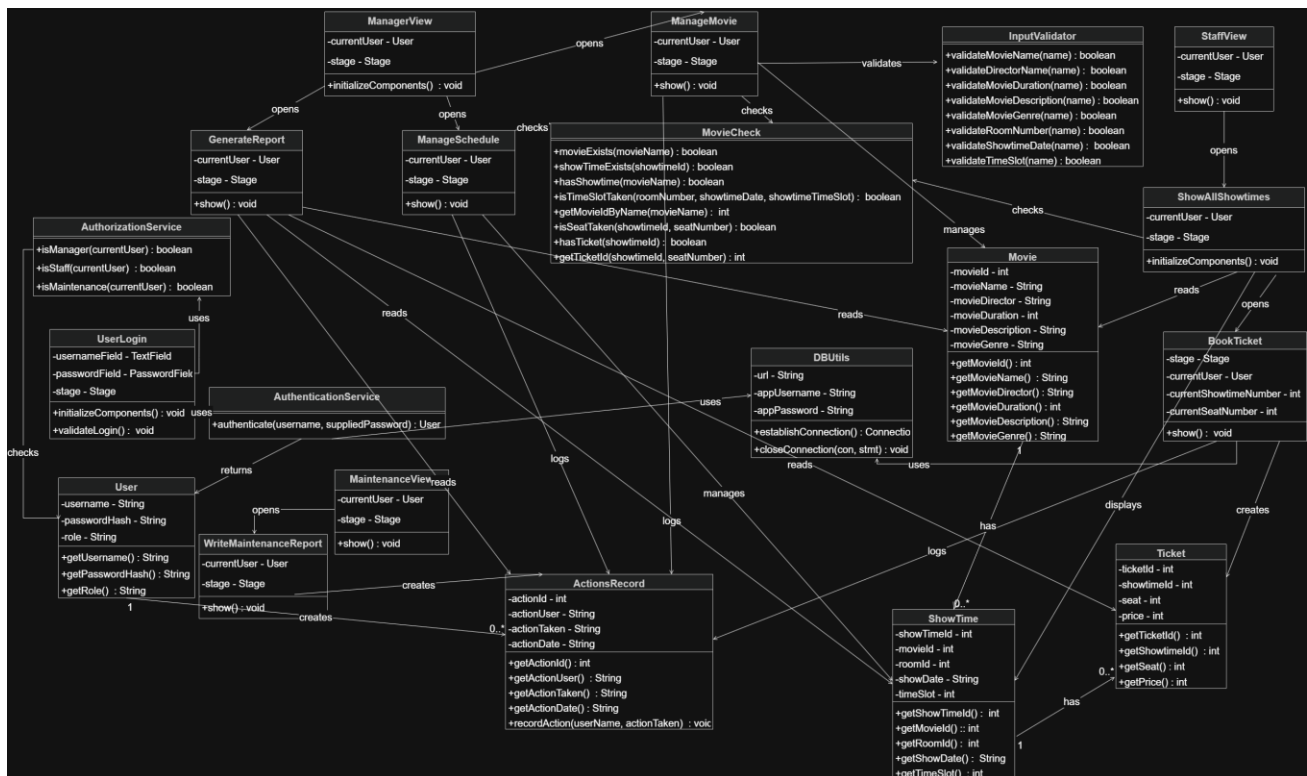


Figure 1. UML Class Diagram of the Movie Theatre Management System

The class diagram above shows the main classes in the current MTMS design. It includes the login and role-check classes, the main user views, the helper classes, and the main data classes used in the system. The diagram focuses on the classes that are most important for understanding the system structure and security.

2.1 Security-Relevant Design Points

- passwords are verified using BCrypt against the users table.
- Failed login attempts are tracked, and an account can be locked after three failed attempts.
- Prepared statements are used in the main database queries.
- Seat availability is checked before a booking is saved.
- Ticket and payment data are saved together in one database transaction.
- Movie and showtime forms use input validation before data is inserted or updated.
- The current showtime flow also checks that the selected room exists before adding a new showtime.
- Important actions such as adding movies, deleting showtimes, booking tickets, and writing maintenance reports are recorded in the action log.

2.2 Main Tables Used by the Code

Table	What it stores	Used by
users	Login accounts, BCrypt password hashes, roles, failed attempts, and lock status	UserLogin, AuthenticationService, AuthorizationService
movies	movieId, name, director, duration, description, genre	AddMovie, ManageMovie, UpdateMovie, ShowAllMovies, reports
showtime	showtimeId, movieId, room, date, timeSlot	AddShowtime, ManageSchedule, ShowAllShowtimes, reports
ticket	ticketId, showtimeId, seat, price	BookTicket, ShowAllTickets, reports, seat checks
payment	paymentId, ticketId, amount, method	BookTicket
maintenancereport	reportId, equipment, description	WriteMaintenanceReport, ShowAllMaintenanceReports
actions	actionId, actionUser, actionTaken, actionDate	ActionsRecord, ShowAllActions
rooms	roomId, capacity	room existence check before adding a showtime

3. External Entities and Entry Points

Since MTMS is implemented as a software running on the desktop, the external entities are the internal users that are controlling the theatre PC. The major entry points in this scenario include the screen and the fields used by the users to provide input into the system. These entry points are important since they are the exact source of any errors or malpractices.

Entity	Main Entry Points	Main Data Sent	Main Risk
Manager	Login screen, movie management screen, showtime management screen, reports screens, sold tickets screen	username, password, movie data, showtime data, delete/update requests, report requests	Unauthorized manager access would expose powerful functions.
Staff	Login screen, showtimes screen, booking screen, payment method selection	Username, password, showtime ID, seat number, payment method	Bad booking input or misuse can affect seat availability and sales data.
Maintenance Staff	Login screen, maintenance report screen, maintenance report list	username, password, equipment name, report details	False reports or unauthorized viewing can affect maintenance records.

4. Data Flow Diagram and Trust Boundary

In the high-level data flow diagram, we can see the movement of data within the system. Here, Manager, Staff, and Maintenance Staff request actions from the application MTMS. Then, the application validates the inputs, applies logic according to roles, makes SQL queries and processes data in the local database.

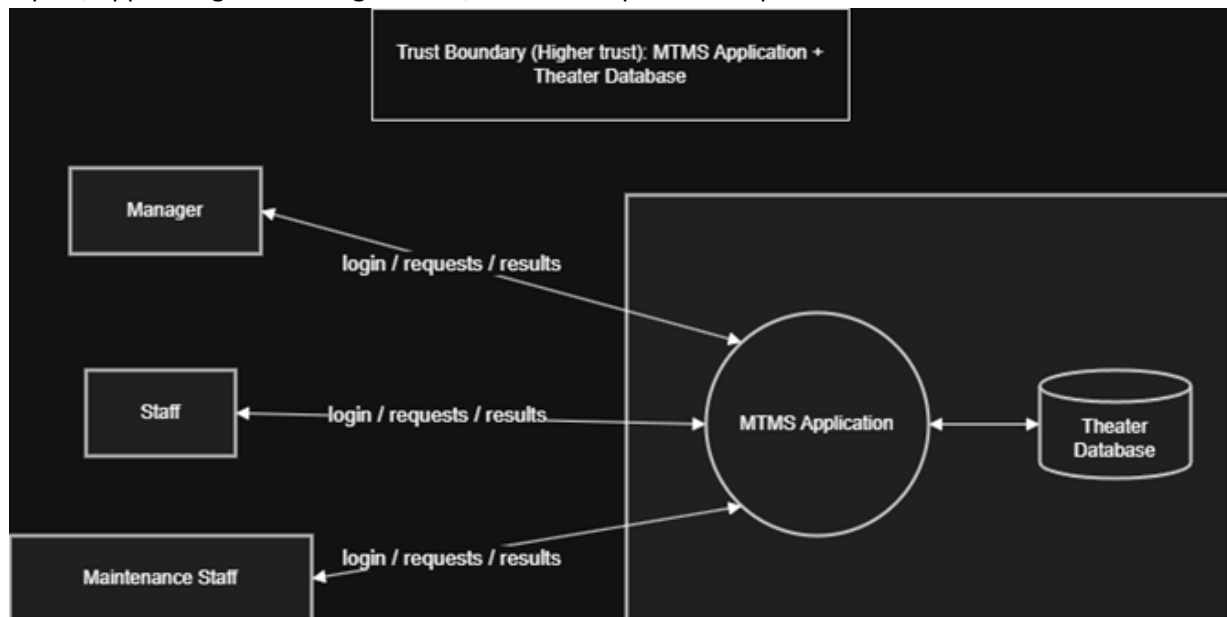


Figure 2. High-Level DFD and Trust Boundary for the MTMS Design

This DFD indicates the boundary where the level of trust varies. The user inputs the information at the initial stage of the process which lies outside the trust boundary. The application forms the initial trust boundary in which the user login details are authenticated, input is validated, booking criteria are applied, and significant events are logged.

4.1 Main Data Flows

- Login flow: username and password are submitted to UserLogin, checked through AuthenticationService and AuthorizationService, then compared against the users table.
- Movie and showtime flow: manager data goes through form validation, existence checks, and database insert/update/delete queries.
- Booking flow: staff selects a showtime and a seat, the system checks that the showtime exists and the seat is free, then saves the ticket and payment.
- Maintenance flow: maintenance staff enters equipment details and report text, the input is validated, and the report is stored in maintenancereport.
- Report flow: manager requests reports, and the application reads from movies, showtime, ticket, actions, and maintenancereport to build the output tables.

5. STRIDE Threat Modelling

After decomposing the application and identifying the main data flows, the next step is to map threats using STRIDE. The threats below are based on the current project design and the actual code features such as login, role routing, movie management, showtime management, ticket booking, maintenance reporting, and action logging.

5.1 STRIDE Threat Table

STRIDE Category	Component	Identified Threat	Initial Rating
Spoofing	Manager	An unauthorized person uses stolen manager credentials or an open session on the theatre PC.	High
Spoofing	Staff	An unauthorized person logs in as Staff and reaches booking functions.	High
Spoofing	Maintenance Staff	An unauthorized person logs in as Maintenance Staff and reaches maintenance reports.	Medium
Spoofing	Database	Someone connects directly to the local database using extracted or weak database credentials.	High
Tampering	Movie / showtime forms	Invalid or manipulated movie or showtime input is submitted to change data in a harmful way.	High
Tampering	Booking flow	A user tries to book the same seat again or manipulates booking input.	High
Tampering	Maintenance reporting	False or misleading maintenance report details are submitted.	Medium
Tampering	database	Movie, showtime, ticket, payment, maintenance, or action log records are edited directly in the database.	High
Repudiation	Manager	A manager denies adding, updating, or deleting movies or showtimes.	Medium
Repudiation	Staff	A staff user denies booking a ticket or choosing a payment method.	Medium
Repudiation	Maintenance	A maintenance user denies writing a maintenance report.	Medium
Repudiation	Action logs	Logs are weak, altered, or deleted, so actions cannot be traced properly.	High
Information Disclosure	Manager	Stolen manager access exposes reports, sold tickets, and action logs.	High
Information Disclosure	Application code	Database URL, username, or password is exposed in code or configuration.	High
Information Disclosure	database	Direct local DB access exposes user hashes, tickets, payments, reports, and logs.	High
Denial of Service	Booking flow	Too many fake bookings are created so seats look unavailable.	High
Denial of Service	Local environment	The local database is deleted, corrupted, or becomes unavailable.	High
Elevation of Privilege	Staff role	A Staff user reaches manager-only screens such as reports or movie management.	High

STRIDE Category	Component	Identified Threat	Initial Rating
Elevation of Privilege	Maintenance role	A Maintenance Staff user reaches manager-only or staff-only functions.	High
Elevation of Privilege	database	A low-privileged local user bypasses the app and performs protected actions directly in the database.	High

6. DREAD Risk Rating

DREAD stands for Damage, Reproducibility, Exploitability, Affected Users, and Discoverability.

The DREAD table below rates the main threats in a simple and practical way for this project. The scale used is 1 to 3 for each factor, then the values are added to get the total out of 15.

Threat	D	R	E	A	D	Total	Rating
Unauthorized person logs in as Manager	3	3	2	3	2	13/15	High
Unauthorized person logs in as Staff	2	3	2	2	2	11/15	Medium
Unauthorized person logs in as Maintenance Staff	2	3	2	2	2	11/15	Medium
Brute-force login attempts	2	2	2	2	2	10/15	Medium
Direct access to the local database using exposed credentials	3	3	2	3	3	14/15	High
Manipulated movie or showtime input	2	2	2	2	2	10/15	Medium
Fake or misleading maintenance report	2	3	2	2	2	11/15	Medium
Action logs changed or deleted	3	3	2	3	2	13/15	High
Unauthorized viewing of reports or action logs	3	2	2	2	2	11/15	Medium
Local database becomes unavailable	3	2	2	3	2	12/15	High
Staff or Maintenance Staff reaches manager-only functions	3	2	2	3	2	12/15	High

Threat	D	R	E	A	D	Total	Rating
Same seat booked more than once for one showtime	2	2	2	2	2	10/15	Medium
Too many fake bookings make seats unavailable	3	3	2	3	2	13/15	High

7. Threat Documentation

The following threat cards document the main threats identified in this project based on the STRIDE and DREAD analysis. The format is kept short on purpose so the threats stay clear and easy to review.

Threat Card 1

Threat Description	Unauthorized login as Manager
Threat Target	Authentication and Authorization
Risk Rating	13/15
Attack Technique	Stolen credentials or an already open session on the theatre PC.

Countermeasures

- Use strong passwords.
- Lock the account after 3 failed attempts.
- Apply role-based access after login.
- Log out after use.

Threat Card 2

Threat Description	Brute-force login attempts
Threat Target	Authentication
Risk Rating	10/15
Attack Technique	Repeated password guessing against user accounts.

Countermeasures

- Keep the 3-attempt logout.
- Reset failed attempts after successful login.
- Review repeated failed logins in the action log.

Threat Card 3

Threat Description	Direct access to the local database
Threat Target	Confidentiality, integrity, and authorization
Risk Rating	14/15
Attack Technique	Using exposed database connection details to access the local database

Threat Description	Direct access to the local database
	directly.

Countermeasures

- Use a stronger database password.
- Restrict direct local database access.
- Use least-privilege database permissions.
- Protect the theatre PC.

Threat Card 4

Threat Description	Manipulated movie or showtime input
Threat Target	Database integrity and application logic
Risk Rating	10/15
Attack Technique	Invalid or malicious values entered through movie and showtime forms.

Countermeasures

- Keep input validation on all forms.
- Keep prepared statements for database queries.
- Reject invalid room, date, time slot, and movie values.
- Check that the selected room exists before adding a new showtime.

Threat Card 5

Threat Description	Same seat booked more than once
Threat Target	Ticket booking integrity
Risk Rating	10/15
Attack Technique	Duplicate booking attempt for the same showtime and seat.

Countermeasures

- Check seat availability before saving.
- Check that the showtime exists.
- Keep ticket and payment in one transaction.
- Reject duplicate reservations.

Threat Card 6

Threat Description	Fake bookings make seats unavailable
Threat Target	Availability and integrity of booking
Risk Rating	13/15
Attack Technique	Repeated misuse of the booking feature to block seats.

Countermeasures

- Limit booking to the Staff role.
- Review unusual booking activity.
- Use action logging for accountability.

Threat Card 7

Threat Description	Fake or misleading maintenance report
Threat Target	Integrity and accountability
Risk Rating	11/15
Attack Technique	Submitting false maintenance details to confuse staff or hide a real issue.

Countermeasures

- Restrict the maintenance module to Maintenance Staff.
- Validate report input.
- Store the action in the log.

Threat Card 8

Threat Description	Action logs changed or deleted
Threat Target	Audit trail and repudiation protection
Risk Rating	13/15
Attack Technique	Editing or deleting action log records in the database.

Countermeasures

- Restrict access to the actions table.
- Review logs regularly.
- Keep backups when possible.

Threat Card 9

Threat Description	Unauthorized viewing of reports or action logs
Threat Target	Confidentiality and authorization
Risk Rating	11/15
Attack Technique	Using stolen manager access or weak role checks to open protected screens.

Countermeasures

- Show reports through the manager interface only.
- Check role before opening protected modules.
- Protect user credentials.

Threat Card 10

Threat Description	Staff or Maintenance Staff reaches manager-only functions
Threat Target	Authorization
Risk Rating	12/15
Attack Technique	Bypassing role flow to open manager-only features such as reports or movie management.

Countermeasures

- Enforce role-based access control.
- Deny protected modules to unsupported roles.
- Keep manager options only in the manager interface.

Threat Card 11

Threat Description	Unauthorized login as Staff
Threat Target	Authorization and authentication
Risk Rating	11/15
Attack Technique	Stolen Staff credentials or an already open session on the theatre PC.

Countermeasures

- Use strong passwords.
- Lock the account after 3 failed attempts.
- Apply role-based access after login.

- Log out after use.

Threat Card 12

Threat Description	Local database becomes unavailable
Threat Target	Availability of the system and stored data
Risk Rating	12/15
Attack Technique	The local database is deleted, corrupted, or becomes unavailable because of local misuse, system failure.

Countermeasures

- Restrict direct access to the local database.
- Protect the theatre PC from unauthorized local use.
- Keep database backups when possible.
- Use stronger database credentials and limited permissions.

Threat Card 13

Threat Description	Unauthorized login as Maintenance Staff
Threat Target	Authentication and authorization
Risk Rating	11/15
Attack Technique	Stolen Maintenance Staff credentials or an already open session on the theatre PC.

Countermeasures

- Use strong passwords.
- Lock the account after 3 failed attempts.
- Apply role-based access after login.
- Log out after use.

8. Conclusion

In general, the MTMS model seems suitable for a desktop theatre system. The threat model identifies the potential threats, which are unauthorised login, unauthorised database access, poor role management, malicious input, and malicious use of the booking function. The existing system already has some security

measures, including password verification using BCrypt, account lockout, SQL statement precompilation, seat verification, room verification, booking via transactions, and action logging. This is a local desktop system, and so the primary concerns would be securing the theatre PC, database access security, and role/input validation.